Unify Repo Malware Incident Report

Oct 31, 2026 · @Dibble

Summary

Malware is in the `main` branch and five other branches of the Unify repository (`DIBBLS/Unify`) as of the last check on Oct 30, and it was pushed into `main` twice in October. The likely source is the machine behind Ifet's GitHub account (`knight-dev01`), which made both pushes to `main`. Sam's machine appears to be infected too. Nothing in the history suggests anyone did this on purpose.

Do these first:

1. Pause Vercel auto-deploys, then rotate every key that build could reach (Vercel environment variables, Firebase, GitHub tokens), from a clean device.
2. Ask Ifet and Sam to stop pushing and syncing until their machines are scanned.
3. Revert `main` to the last clean commit, but only after step 2, or the malware re-injects itself.

Timeline

The malware first reached `main` on Oct 17, Sam removed it on Oct 20, and it came back on Oct 27. Times are Lagos time, newest first.

Date	Event	Detail
Oct 27, 12:13	Malware back in `main`	Sync commit `8efd3a8`, authored by Ifet Great and pushed by `knight-dev01`. It is a second variant, with a different wallet address.
Oct 20, 10:05 to 10:06	Five of Sam's branches get malware	Commits titled "remove malicious VS Code task" add a fake font file and an auto-run VS Code task. Five pushes in 23 seconds, which looks scripted.

Date	Event	Detail
Oct 20, 09:41	Sam cleans `main`	Commit `01107d4`, "remove supply-chain malware dropper". At 09:43 he opens issue #37 tagging `@Abdullateef2006`, `@DIBBLS` and `@knight-dev01`.
Oct 17, 13:26	First infection of `main`	Sync commit `24791bf`, authored as the default identity "Your Name" and pushed by `knight-dev01`. It adds about 28 KB of hidden code to `api.js` and 13 KB to `vite.config.js`.
Sep 17	Last clean state of those files	Commit `67b876c`: `api.js` empty, `vite.config.js` 332 bytes.

Sync commits from Oct 20 to Oct 26 were clean.

What is affected

`main` and five of Sam's branches are infected; the other 24 of 30 branches are clean. `main` was still on the infected commit `8efd3a8` when checked on Oct 31.

Where	How it is infected	Effect
`main`	Hidden code after thousands of spaces on one line of `api.js` and `vite.config.js`	Vite reads `vite.config.js` on every dev run and build, including a Vercel deploy
`claude/funny-noether-5gllhn` (PR #34)	Fake font file `public/fonts/fa-solid-300.ttf` plus a hidden auto-run task in `.vscode/tasks.json`	Opening the folder in VS Code runs it

Where	How it is infected	Effect
`claude/deploy-1782137664`, `claude/trigger-deploy`, `claude/unify-admin-dashboard-c35u90`, `claude/unify-learn-branding-controls-fpoer1`	Same fake font file and task	Same

The scan covered all 30 branch tips for both known variants (two different wallet addresses), for hidden very long lines, and for `.vscode/tasks.json`. It did not cover older commits on the clean branches, or your other repositories.

What the malware does

It runs a hidden program that finds its controller's address on the Ethereum blockchain, downloads a second program from there and runs it in the background. I read the code and did not run it.

- **How it starts:** when someone opens the folder in VS Code (the `.vscode/tasks.json` route), or runs a dev server or build that loads `vite.config.js`. Neither needs `npm install`.
- **How it hides:** the code sits after thousands of spaces on one line, or inside a file named like a font, so it looks empty or harmless in an editor.
- **How it finds its server:** it reads transactions from a fixed Ethereum wallet and decodes an IP address from them. The attacker can change that address at any time, so blocking one IP does not help.
- **What it steals:** I did not see the second stage. Sam's issue #37 reports a clipboard stealer, and this kind of malware is built to take credentials, tokens and keys.
- **Two variants:** the version Sam describes names one wallet and the Oct 27 code names another, so they are not identical copies.

Where it came from

The history points to Ifet's machine first and Sam's second, but it cannot show who was infected first or how the malware first arrived.

What the evidence shows

- `knight-dev01`, which you confirmed is Ifet's account, pushed both infections into `main`, on Oct 17 and Oct 27.
- The malware returned on Oct 27, a week after Sam cleaned `main` and warned the team. That fits a machine that was never cleaned, because this kind of malware re-injects itself into commits.
- Sam's five Oct 20 branch commits are titled as a fix but add the malware. Five pushes in 23 seconds look scripted, which fits Sam's machine being infected or a script running on it. Only Sam can confirm.
- Sam found the Oct 17 infection himself with a scanner and reported it in issue #37. That does not fit someone hiding it.

What it cannot show

- How the malware first reached either machine.
- Which of the two machines was infected first.
- Whether the sync script runs only on Ifet's laptop.

How to find the start: ask both whether they opened or ran anything from outside the team around Oct 15 to 17. Examples are a coding test, a zip file or a project from a recruiter or client, or an unfamiliar npm package. This kind of malware commonly arrives that way. Treat both as likely victims, not culprits.

Immediate actions

Stop the exposure first, then clean the machines, then clean the repository; cleaning the repository first only gets it re-infected.

- [ ] You: pause auto-deploys for Unify on Vercel.
- [ ] You: rotate the Vercel environment variables, Firebase keys and any other keys the app uses, from a clean device.
- [ ] You: revoke and regenerate your GitHub tokens, and check your account for SSH keys, OAuth apps or workflows you did not create.
- [ ] You: tell Ifet and Sam to stop pushing and to stop the auto-sync script (probably `temp_auto_push.bat`, which is listed in `.gitignore`).
- [ ] Ifet and Sam: scan their machines using the commands in issue #37, then rotate their GitHub tokens, passwords and `.env` keys from a different, clean device. If unsure, wipe the machine.

- [ ] Ifet and Sam: delete their local clones and re-clone after the machine is clean.
- [ ] Once the machines are clean: revert `main` to commit `c0a2d1a` (Oct 26, checked clean against both variants), close PR #34 and delete the five infected branches.
- [ ] Check the repository's Actions workflows for anything nobody created.
- [ ] Run the same scan on your other repositories: Unify-clone, Unify-Operations, unify-notes-engine and Unify-Scan.

Hardening

Making the repository private is worth doing, but branch protection is what would have stopped this, because the malware was pushed by team accounts, not read by outsiders.

Control	What it stops
Branch protection on `main`: pull request and one approval required, no direct pushes	An automated sync pushing straight into `main`
Least access: write access only to their own branches for most devs, admin for you alone	One infected account changing `main`
2FA on every developer's GitHub account	Stolen passwords alone being enough
A CI check that fails on a `folderOpen` task in `.vscode/tasks.json`, code lines over 4,000 characters, or the two wallet addresses	The next injection, before it merges
Private repository	Strangers reading or copying the code. It does not stop pushes from an infected developer machine, and anything ever committed while public should be treated as already copied.

Open questions

- Which machine runs the "frontend sync", and since when? Its commits changed from "Your Name" to Ifet Great on Oct 20 at 13:11.
- Did Ifet or Sam open anything from outside the team around Oct 15 to 17?
- What did Sam's push to `main` and six branches on Oct 18 at 20:32 contain? I did not inspect it.

- Who is `@Abdullateef2006`, tagged in issue #37 but not seen as a committer in this history, and do they still have access?
- Does Vercel deploy from `main`, and did a deploy run after Oct 27 at 12:13?
- Have any keys been rotated yet?